

Chapitre 7

La cyber-résilience — panorama des pratiques

Feuille d'exercices

Jaouad Madkour

Faculté d'Économie et de Gestion de Tanger
Exercices et corrigés · Risque opérationnel et résilience

1 Exercices du chapitre

Exercice 1 — La cyber-résilience selon le FSB, gouvernance et positionnement du RSSI

- (a) Le Comité de Bâle retient la définition du Conseil de stabilité financière (FSB) : « la cyber-résilience est la capacité d'une organisation à poursuivre sa mission en anticipant et en s'adaptant aux cybermenaces, et en résistant, contenant et se rétablissant rapidement des incidents cyber », une distinction étant établie entre la gestion du **risque cyber** (« vulnérabilités et menaces spécifiques ») et la gestion du **risque informatique** au sens large, « dont le périmètre dépasse ce rapport ». Identifier, dans cette définition, les cinq verbes d'action successifs qui la composent (anticiper, s'adapter, résister, contenir, se rétablir), et expliquer pourquoi ils décrivent un cycle complet plutôt qu'une seule capacité isolée. Pourquoi le risque cyber constitue-t-il, selon cette distinction, un sous-ensemble du risque informatique plutôt que son équivalent, et pourquoi le rapport choisit-il explicitement d'exclure ce périmètre plus large de son analyse ?
- (b) Le rapport constate que « l'automatisation croissante, le recours généralisé aux prestataires tiers et l'essor de l'informatique en nuage élargissent la surface d'attaque accessible aux cyber-adversaires et rendent le périmètre de la supervision partagé entre l'institution régulée et ses fournisseurs », un constat posé en 2018 par le G20 puis approfondi par le Comité de Bâle. Expliquer précisément, pour chacun des trois facteurs cités (automatisation, prestataires tiers, cloud), le mécanisme par lequel il élargit concrètement la « surface d'attaque » de l'institution. Pourquoi ce même constat implique-t-il nécessairement que le périmètre de la supervision devienne « partagé », plutôt que de rester une prérogative exclusivement interne à l'institution régulée ?
- (c) La plupart des régulateurs « n'imposent pas formellement l'adoption d'une stratégie de cybersécurité autonome, mais tous attendent des institutions régulées qu'elles disposent d'une stratégie de sécurité de l'information approuvée par le conseil d'administration », trois approches réglementaires coexistant : l'autorité impose des exigences sectorielles directement ; les établissements élaborent leur propre stratégie évaluée par le superviseur ; ou le superviseur vérifie simplement l'existence d'une stratégie informatique assortie de dispositions de sécurité. En vous appuyant sur l'étude de cas 1, décrire précisément ce que couvre chacun des trois cadres réglementaires cités (la norme australienne CPS 234, les circulaires allemandes MaRisk et BAIT, la proposition des régulateurs américains) et identifier, pour chacun, laquelle des trois approches réglementaires il illustre le mieux.
- (d) Le modèle des trois lignes de défense place typiquement le RSSI « sous l'autorité du directeur des risques (CRO) ou du directeur des systèmes d'information (CIO) », mais une tendance émergente considère le rattachement au CRO comme « sous-optimal : les deux fonctions ont des priorités potentiellement contradictoires, le CRO privilégiant la conformité quand le RSSI cherche à concilier innovation technologique et sécurité », ce qui a conduit plusieurs grandes banques à faire remonter le RSSI « directement au directeur général ou au conseil d'administration ». Expliquer précisément en quoi consiste la contradiction de priorités entre CRO et RSSI décrite par le cours, et pourquoi un rattachement hiérarchique direct à la direction générale ou au conseil est présenté comme une réponse à cette contradiction plutôt qu'un simple changement d'organigramme. En quoi la culture de sensibilisation au risque cyber — « une formation de sensibilisation à chaque étape du parcours d'un salarié, du recrutement au départ », complétée par des programmes de formation dédiés au conseil d'administration lui-même (étude de cas 3) — constitue-t-elle un levier complémentaire à ce repositionnement hiérarchique du RSSI, plutôt qu'un substitut à celui-ci ?

Exercice 2 — Superviser, tester et mesurer la cyber-résilience : TIBER-EU, Resilient Shield et les indicateurs

- (a) Les spécialistes des risques « s'appuient sur des preuves documentaires, des inspections physiques, des rapports d'incidents et des enquêtes pour évaluer l'adéquation des contrôles, en cohérence avec des référentiels tels que COBIT et NIST », la cartographie et la classification des services d'affaires critiques constituant « un préalable à tout dispositif de test et d'assurance

robuste ». Énumérer les quatre types de preuves mobilisées par la supervision cyber selon le cours. Pourquoi la cartographie et la classification préalables des services critiques doivent-elles précéder tout dispositif de test, plutôt que de tester indistinctement l'ensemble du système d'information d'une institution ?

- (b) La Banque centrale européenne a publié en mai 2018 le cadre TIBER-EU, « premier dispositif transfrontalier de tests d'intrusion ciblés et réalistes contre les institutions financières », réalisé par des prestataires spécialisés en renseignement de la menace, des tests qui « ne donnent pas lieu à un résultat pass/fail mais fournissent à l'entité testée une évaluation de ses forces et faiblesses pour progresser en maturité cyber ». Expliquer précisément pourquoi l'abandon d'un format binaire pass/fail sert spécifiquement l'objectif affiché de « progresser en maturité cyber », en contraste avec ce qu'aurait produit un test de conformité classique à résultat binaire. Le caractère « ciblé et réaliste » de ces tests (par opposition à un test générique) est-il compatible avec l'absence de notation pass/fail, ou ces deux caractéristiques répondent-elles à des logiques distinctes ?
- (c) En 2015, le Royaume-Uni et les États-Unis ont mené l'exercice conjoint « Resilient Shield », destiné à « renforcer la coordination et la compréhension mutuelle des processus de partage d'information et de réponse aux incidents entre gouvernements et secteur financier », un exercice qui « ne testait ni des firmes individuelles ni les systèmes financiers eux-mêmes, mais les mécanismes de communication et de coordination entre autorités ». Expliquer précisément ce que cet exercice a délibérément choisi de *ne pas* tester, et en quoi cela le distingue fondamentalement de TIBER-EU. Quelle vulnérabilité spécifique — distincte d'une vulnérabilité technique au sein d'une institution — un exercice de coordination inter-gouvernementale de ce type cherche-t-il précisément à révéler et à corriger ?
- (d) La plupart des juridictions « se concentrent encore sur des indicateurs rétrospectifs (incidents déjà survenus, résultats de tests passés), pertinents lorsque l'environnement est stable — ce qui n'est pas le cas face à des adversaires cyber qui adaptent continuellement leurs tactiques », le vieillissement des correctifs de sécurité (patch ageing) illustrant « la nécessité de développer des indicateurs prospectifs de résilience, encore peu harmonisés d'une juridiction à l'autre ». Expliquer précisément pourquoi le patch ageing — le temps écoulé entre la disponibilité d'un correctif et son déploiement effectif — constitue un indicateur *prospectif* plutôt que purement rétrospectif, alors même qu'il repose sur une mesure de délais déjà écoulés. En quoi l'hypothèse implicite d'un « environnement stable », nécessaire à la pertinence des indicateurs rétrospectifs, est-elle précisément ce que des adversaires cyber « qui adaptent continuellement leurs tactiques » rendent structurellement caduque ?

Exercice 3 — Le partage d'information et la gouvernance des tiers

- (a) Le rapport distingue cinq types de partage d'information de cybersécurité : « entre banques, des banques vers leurs régulateurs, entre régulateurs, des régulateurs vers les banques, et avec les agences de sécurité nationales », le partage entre banques et avec les agences de sécurité étant « le plus répandu », tandis que « le partage entre régulateurs reste le moins observé, en partie du fait de sa nature souvent informelle et bilatérale ». Énumérer les cinq catégories de flux d'information. Pourquoi le caractère « informel et bilatéral » du partage entre régulateurs freine-t-il spécifiquement sa diffusion, alors que ce même caractère bilatéral ne semble pas empêcher, par exemple, l'accord Hong Kong-Singapour étudié plus loin de fonctionner efficacement ?
- (b) Le FS-ISAC, organisation à but non lucratif créée en 1999 aux États-Unis, « collecte et diffuse en temps réel, via son système propriétaire CINS, des alertes de vulnérabilités et de menaces cyber entre ses membres », les informations partagées étant « anonymisées pour ne jamais permettre de remonter à la source, un principe de confidentialité jugé essentiel pour encourager la participation volontaire des membres ». Expliquer précisément le lien de causalité entre anonymisation et participation volontaire : que risquerait de se produire si une banque membre du FS-ISAC savait que signaler une vulnérabilité subie l'exposerait, sans anonymisation, à être identifiée nommément par ses concurrents ou par le marché ?

- (c) La Hong Kong Monetary Authority et l'Autorité monétaire de Singapour ont établi en 2018 un cadre bilatéral fondé sur cinq principes : rapidité (partage sous 24 heures en cas de risque de propagation transfrontalière), caractère volontaire, confidentialité, efficacité (partage non limité aux seules institutions présentes dans les deux juridictions), et usage d'un protocole de classification standardisé (Traffic Light Protocol) et d'une taxonomie commune (STIX). Énumérer les cinq principes de cet accord. En quoi la standardisation via TLP et STIX sert-elle spécifiquement le principe d'« efficacité », qui exige que le partage ne soit pas limité aux seules institutions présentes dans les deux juridictions fondatrices ? Par ailleurs, la directive européenne NIS (effective depuis mai 2018) impose l'établissement de CSIRT nationaux, la notification d'incidents à ces CSIRT étant « obligatoire pour les opérateurs de services essentiels ». À laquelle des cinq catégories de flux d'information identifiées au (a) ce mécanisme de notification obligatoire correspond-il, et en quoi son caractère *obligatoire* le distingue-t-il du caractère « volontaire » de l'accord Hong Kong-Singapour ?
- (d) Pour ce rapport, la notion de « tiers » couvre « l'ensemble des formes d'externalisation (y compris l'informatique en nuage), les produits et services standardisés habituellement non considérés comme de l'externalisation (alimentation électrique, télécommunications), et les contreparties interconnectées telles que les infrastructures de marché », les régulateurs attendant des institutions un « cadre d'externalisation approuvé par le conseil [...] et des clauses contractuelles garantissant un droit d'inspection et d'audit — parfois étendu directement aux autorités de supervision, comme en France, en Suisse et à Singapour ». Pourquoi le fait de classer un fournisseur d'« alimentation électrique » — normalement non considéré comme de l'externalisation — dans le même périmètre de gouvernance des tiers que les prestataires cloud change-t-il concrètement la façon dont une institution doit gérer sa relation contractuelle avec lui ? Par ailleurs, certains grands fournisseurs de cloud organisent des « sommets réglementaires » réunissant plusieurs autorités de supervision, dans un format proche du « collège de superviseurs » habituellement réservé aux grandes institutions bancaires internationales. Quel problème précis, énoncé par le cours comme « la difficulté, pour un régulateur national isolé, d'exercer une supervision effective sur un fournisseur mondial », ce format de sommet réglementaire cherche-t-il à résoudre ?

2 Exercice cumulatif (chapitres 7, 6, 5, 4, 3)

Exercice 4 — La cyber-résilience à la lumière des quatre chapitres précédents

- (a) Le chapitre 6, en détaillant la deuxième ligne de défense d'une grande banque, énumère « un directeur des risques de crédit (CRO), un directeur des risques de marché, un directeur des risques de liquidité [...], un responsable de la sécurité de l'information (RSSI, voir chapitres 7-8) », et attribue à un « comité des risques du conseil d'administration [...] la supervision de l'ensemble des risques de l'organisation ». Ce chapitre tient très exactement la promesse de ce renvoi en détaillant le positionnement hiérarchique du RSSI (sous le CRO, sous le CIO, ou directement sous la direction générale ou le conseil) et en exigeant « une stratégie de sécurité de l'information approuvée par le conseil d'administration ». Montrer comment l'exigence de ce chapitre d'une stratégie cyber « approuvée par le conseil » est une application directe, au cas particulier du risque cyber, du rôle général que le chapitre 6 attribue au comité des risques du conseil sur « l'ensemble des risques ». Le chapitre 6 présente par ailleurs son énumération de responsables de deuxième ligne (crédit, marché, liquidité, RSSI) comme un organigramme relativement net, chaque risque ayant « son » responsable dédié. En quoi le débat de ce chapitre sur le rattachement « sous-optimal » du RSSI au CRO complique-t-il cette lecture simple du chapitre 6, en révélant qu'une deuxième ligne organisée « par type de risque » peut receler des tensions internes entre ses propres fonctions plutôt qu'une simple juxtaposition harmonieuse de spécialités ?
- (b) Le chapitre 5 range les « risques émergents », identifiés par une « veille prospective (horizon scanning) », parmi les sept composantes d'un reporting abouti, une composante qui,

contrairement aux autres, « est tournée vers l’avenir », et décrit un modèle à trois strates où un incident isolé remonte en détail au niveau opérationnel, mais où « s’il révèle une faiblesse structurelle de contrôle affectant l’appétit pour le risque de l’organisation, seule sa conclusion [...] remonte au conseil d’administration ». Ce chapitre constate que « la plupart des juridictions se concentrent encore sur des indicateurs rétrospectifs » et que le patch ageing « illustre la nécessité de développer des indicateurs prospectifs de résilience, encore peu harmonisés ». Montrer que le patch ageing de ce chapitre est un cas concret et chiffrable de ce que le chapitre 5 ne fait que nommer abstraitement sous le terme de « veille prospective » appliquée au risque cyber, et que le retard constaté par ce chapitre dans le développement de tels indicateurs illustre, pour le domaine cyber spécifiquement, un manque que le chapitre 5 identifie de façon générale pour l’ensemble du risque opérationnel. Par ailleurs, une évaluation TIBER-EU qui révélerait une faiblesse structurelle de la gouvernance cyber d’une institution devrait-elle, selon la logique du « gâteau du reporting » du chapitre 5, remonter dans le détail au conseil d’administration, ou seulement sous forme de conclusion synthétique ? Justifier la réponse à partir de la citation du chapitre 5 reproduite ci-dessus.

- (c) Le chapitre 4 range les événements « extrêmes de type cyber » parmi les risques pour lesquels « une assurance a du sens [...] pour les risques prévisibles, correctement tarifiables, et facilement transférables », et pose que « l’externalisation ne transfère jamais la responsabilité vis-à-vis du client final ». Ce chapitre détaille, pour le risque cyber spécifiquement, un « cadre d’externalisation approuvé par le conseil [...] et des clauses contractuelles garantissant un droit d’inspection et d’audit » envers les prestataires tiers et les fournisseurs cloud. Montrer que ce dispositif contractuel de ce chapitre est une déclinaison précise, au cas du risque cyber porté par des tiers, du principe général du chapitre 4 selon lequel l’externalisation « ne transfère jamais la responsabilité » : que resterait-il à l’institution comme moyen de maîtrise du risque cyber logé chez un tiers, si elle ne pouvait ni transférer sa responsabilité ni exercer de droit d’audit contractuel ? Par ailleurs, le chapitre 4 distingue quatre niveaux de rigueur croissante pour tester un contrôle, de l’auto-certification jusqu’à la « reperformance [...] la forme de test la plus exigeante », illustrée par « le client mystère ou l’insertion de transactions fictives ». Montrer que le test d’intrusion TIBER-EU de ce chapitre est, dans son principe, une instance du niveau de rigueur le plus élevé défini au chapitre 4 — la reperformance — appliquée non à un contrôle isolé mais à l’ensemble du dispositif de cyber-résilience d’une institution.
- (d) Le chapitre 3, dans sa section « Quantifier la résilience », définit une démarche en sept étapes dont la troisième consiste à « cartographier les ressources et dépendances nécessaires à [la] délivrance » des services opérationnels importants (IBS), et identifie les points de défaillance uniques (SPOF) — notamment la « dépendance [...] à un prestataire cloud unique » — comme des « indicateurs clés de résilience à surveiller en priorité, et à éliminer par la redondance lorsque c’est possible ». Ce chapitre pose que « la cartographie et la classification des services d’affaires critiques constituent un préalable à tout dispositif de test et d’assurance robuste » en matière cyber. Montrer que cette exigence de ce chapitre est très exactement l’application, au domaine cyber, de la troisième étape de la méthode générale du chapitre 3 : sans la cartographie des dépendances qu’exige le chapitre 3, sur quoi porterait exactement le « préalable » que ce chapitre exige avant tout test d’intrusion ou toute mesure de résilience cyber ? Montrer par ailleurs que l’exemple de SPOF du chapitre 3 — un « prestataire cloud unique » — annonce très précisément le sujet même de la section de ce chapitre consacrée aux interconnexions tierces et à la gouvernance du cloud : en quel sens ce chapitre ne fait-il que déployer, pour le cas particulier du fournisseur cloud, un risque que le chapitre 3 avait déjà identifié comme structurel, mais sans en détailler le dispositif de gouvernance (droit d’audit, sommets réglementaires) que ce chapitre fournit ?

3 Applications en sciences économiques

Exercice 5 — Le vieillissement des correctifs (patch ageing) : un indicateur prospectif chiffré

Une banque construit son indicateur de vieillissement des correctifs de sécurité (patch ageing) sur quatre familles de systèmes. Pour chacune, elle recense le nombre de correctifs critiques appliqués en retard sur l'année (n), leur âge moyen de retard en jours, et un coût d'exposition estimé par « jour-vulnérabilité » (probabilité et sévérité combinées d'une exploitation pendant la fenêtre de retard) :

Système	Correctifs en retard (n)	Âge moyen (jours)	Coût d'exp. (€/jour-vuln.)
Cœur bancaire	8	12	3 000
Canaux clients (web/mobile)	15	28	1 200
Back office	5	45	600
Prestataire cloud tiers	6	60	2 000

La politique interne de cyber-résilience de la banque fixe un seuil d'alerte de 30 jours pour l'âge moyen des correctifs critiques, individuellement par système et pour le portefeuille dans son ensemble.

- Pour chaque système, calculer l'exposition en « jours-vulnérabilité » (nombre de correctifs en retard multiplié par leur âge moyen), puis le coût d'exposition associé (jours-vulnérabilité multipliés par le coût par jour-vulnérabilité). Calculer le coût d'exposition total du portefeuille.
- Calculer la contribution de chaque système au coût d'exposition total, en pourcentage. Quel système domine cette exposition chiffrée, et ce système est-il celui dont l'âge moyen de retard est le plus élevé ? Commenter l'écart éventuel entre le classement par âge moyen et le classement par coût d'exposition.
- Calculer l'âge moyen pondéré des correctifs pour l'ensemble du portefeuille (pondéré par le nombre de correctifs n de chaque système). Ce chiffre pondéré dépasse-t-il le seuil d'alerte de 30 jours fixé par la banque ? Identifier séparément les systèmes qui, pris individuellement, dépassent déjà ce même seuil.
- Le comité des risques envisage un investissement de 45 000 € par an dans un audit renforcé du prestataire cloud tiers (droit d'inspection contractuel renforcé, cf. le cours), qui ramènerait l'âge moyen de retard de ce seul système de 60 à 20 jours, sans changer le nombre de correctifs concernés. Calculer le nouveau coût d'exposition de ce système, la réduction de coût d'exposition ainsi obtenue, et le bénéfice net de l'investissement (réduction moins coût annuel de l'investissement). Recalculer l'âge moyen pondéré du portefeuille après cet investissement : repasse-t-il sous le seuil d'alerte de 30 jours ?

Exercice 6 — La valeur du partage d'information : FS-ISAC et l'accord Hong Kong–Singapour, chiffrés

Un secteur bancaire compte $N = 40$ banques, toutes membres d'un centre d'échange d'information de type FS-ISAC. Une cyberattaque de type « spray » touche une première banque du secteur. Tant que la vulnérabilité exploitée n'est pas contenue collectivement, chacune des 39 autres banques du secteur, non encore touchées, court chaque jour un risque additionnel de compromission de 2 % par jour (on utilise, pour simplifier le calcul, une approximation linéaire sans effet de composition : nombre de banques additionnellement compromises $\approx$ banques restantes $\times$ probabilité journalière $\times$ nombre de jours d'exposition). Le coût moyen, direct et réputationnel, d'une banque compromise est de 2 500 k€.

- Sans aucun partage d'information, la vulnérabilité met en moyenne 6 jours à être détectée et corrigée à l'échelle du secteur. Avec un partage de type FS-ISAC (ou l'accord bilatéral Hong Kong–Singapour, qui impose un partage « sous 24 heures en cas de risque de propagation transfrontalière »), cette fenêtre est ramenée à 1 jour. Calculer, dans chacun des deux cas, le nombre de banques additionnellement compromises (au-delà de la première).
- Calculer, dans chacun des deux cas, le nombre total de banques touchées (banque initiale incluse) et la perte sectorielle attendue correspondante. Calculer la réduction de perte attendue permise par le partage d'information, en k€ et en pourcentage relatif de la perte sans partage.

- (c) Chaque banque paie une cotisation annuelle de 80 k€ pour appartenir au centre d'échange d'information, soit un coût total de $80 \times 40 = 3\,200$ k€ par an pour le secteur. En supposant qu'une attaque de cette nature survient en moyenne une fois tous les deux ans à l'échelle du secteur (soit une fréquence annuelle de 0,5), calculer le bénéfice annualisé du partage d'information (réduction de perte du (b) multipliée par cette fréquence), le bénéfice net annuel (bénéfice annualisé moins coût total de cotisation), et le ratio bénéfice/coût. Le dispositif de partage d'information est-il justifié économiquement à l'échelle du secteur ?
- (d) Le cours souligne que l'anonymisation des informations partagées par le FS-ISAC est « un principe de confidentialité jugé essentiel pour encourager la participation volontaire des membres ». Supposons que la suppression de ce principe d'anonymat réduise la participation effective et prompte des banques, portant le délai moyen de détection et de correction collective de 1 à 3 jours (au lieu des 6 jours du scénario sans aucun partage). Calculer le nombre de banques additionnellement compromises et la perte sectorielle attendue dans ce scénario dégradé, puis la réduction de perte qu'il permet encore par rapport à l'absence totale de partage. Calculer enfin le « coût de la perte du principe d'anonymat » : l'écart, en k€ par événement puis annualisé (même fréquence qu'au (c)), entre la réduction de perte obtenue avec anonymisation intégrale (b) et celle obtenue dans ce scénario dégradé. Quelle proportion du bénéfice total du partage d'information ce seul renoncement au principe d'anonymat ferait-il perdre ?